

# TrustBank CBS (.NET 10) — Principal-Level Architecture Review

**System:** TrustBank Core Banking System — strangler-fig migration from ASP.NET WebForms / VB.NET / .NET 4.8 to .NET 10 / C# MVC

**Solution:** TflCbsNet10Sol (26 projects) **Review date:** 2026-07-10 **Reviewer posture:** Principal Software Architect / Enterprise Solution Architect — formal pre-production architecture review of a mission-critical, regulated banking system. **Method:** Full source inspection across all layers (solution structure, framework, services/data, presentation/hosts, security/config, testing/DevOps). Every material finding is anchored to `file:line`. Headline Critical findings were re-verified directly against source.

**One-paragraph verdict.** This is, at the *code-craft* level, one of the cleaner migration codebases you will review: a genuinely well-factored horizontal framework, a disciplined `Result`-returning service layer with end-to-end `async / CancellationToken`, real transactions on the money paths that exist, parameterized SQL, no god classes, and an enforced `framework.Screen` boundary. It is **not production-ready** for a bank, and the gap is not craft — it is **security hardening, operational maturity, and migration completeness**. There is a config-reachable authentication bypass, no CSRF protection on any POST, passwords stored under reversible encryption, production credentials committed to config, no source control, no CI/CD, no metrics/tracing, no DB change management, and no DR/HA posture. Roughly **<2% of the ~1,458-screen / ~5,300-proc legacy scope** has been migrated — so what exists is best understood as an **excellent reference architecture and vertical slice**, not a shippable core banking system. Fix the security-critical items before *any* production exposure; treat the rest as the roadmap the (already strong) foundation was built to carry.

🔗 **Remediation progress — updated 2026-07-17** (*this note post-dates the 2026-07-10 review; the findings below are preserved as the original baseline*). Active hardening has closed **4 of the 8 gate items**. **Done:** **C-1** authentication bypass (fail-closed guard + a pinned DB-free test); **C-2** reversible passwords → salted **PBKDF2** end-to-end (new `PasswordHash` primitive in `TflSecurityCrypto`; all 1,731 users migrated; login now verifies against `a_user.PASSWORDHASH`; anonymous pre-login change-password screen shipped); **H-1** global CSRF/antiforgery ( `AutoValidateAntiforgeryToken` registered once in `AddCbsFramework`, token header wired for the AJAX helpers); **H-2** DB credentials removed from every committed `appsettings.json` (real creds now in gitignored `appsettings.Development.json` + prod env/secret-store; **sa password rotation and a least-privilege login remain external follow-ups**). **Remaining gate items:** H-3 (git + CI), H-4 (guard-ordering assertion), H-6 (optimistic concurrency), security headers. **Score:** 62 → ~70, trending to the ~74 gate as the last items close. Per-item status is annotated in the Risk Matrix (§12) and the Production-Readiness Checklist (§15).

## 1. Executive Summary

### What this is

A staged **strangler-fig** rewrite. The legacy WebForms/VB app keeps running; screens are peeled off one at a time into a .NET 10 MVC application composed of per-domain Razor Class Libraries over a shared framework and a `Result`-returning services layer. The team has invested heavily — and effectively — in the *scaffolding for scale*: a reusable framework, reusable UI components, a modular-monolith module system, four deployment shapes (IIS single/multi, Docker single/multi) fronted by a YARP gateway, and unusually thorough documentation.

### The headline

The engineering discipline is high and the architecture *decisions* are mostly sound. The blockers to production are concentrated and fixable, but several are **severe** for a banking context:

| Rank | Blocker                                                                                                                                                                                                              | Severity        |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------|
| 1    | <b>Config-reachable authentication bypass</b> — when the <code>MFA_AD_LOGIN_ENABLED</code> bank variable is non-zero, the password check is skipped and no alternative auth runs → any password logs in a valid user | <b>Critical</b> |
| 2    | <b>Reversible password encryption</b> (not a salted hash) — a DB compromise yields recoverable plaintext passwords                                                                                                   | <b>Critical</b> |
| 3    | <b>No CSRF/antiforgery</b> on any of ~30 POST actions (Login, Logout, all CRUD, dev DB-switch)                                                                                                                       | <b>High</b>     |
| 4    | <b>Production DB credentials committed</b> in base <code>appsettings.json</code> (loaded in Production) using the <code>sa</code> sysadmin account                                                                   | <b>High</b>     |
| 5    | <b>No source control, no CI/CD, no IaC</b> — the working tree is not even a git repository                                                                                                                           | <b>High</b>     |
| 6    | <b>No optimistic concurrency anywhere</b> — read-modify-write lost updates on a banking write path                                                                                                                   | <b>High</b>     |
| 7    | <b>No security headers</b> (CSP / X-Frame-Options / X-Content-Type-Options)                                                                                                                                          | <b>Medium</b>   |
| 8    | ~~No metrics / tracing / APM~~ (✅ instrumented — OTel); <b>no DB migration tooling; no DR/HA</b>                                                                                                                     | <b>Medium</b>   |

Items 1–4 are explicitly acknowledged in the team's own `BACKLOG.md` ("Security hardening: antiforgery... lockout... security headers... PII masking") — they are known and deferred, not unknown. That is a governance point as much as a technical one: **a banking system cannot go live with these deferred.**

**Overall score: ~77 / 100 (current, 2026-07-31 — up from 62 at first review) — "Strong foundation; past the gate number, but not yet green."**

A mid-migration reference implementation that earns praise for craft. As first reviewed (62) it was **rejected for production** on security/operational grounds; since then C-1, C-2, H-1, H-4, and M-1 (security headers) have been fixed, H-2 partially, plus **Observability** instrumentation done early and the **H-6 State pilot** landed (→ ~74), **#12 DB migration tooling + versioned DDL** shipped (→ ~75), and the **controller/HTTP + browser test tiers** landed, closing the ~90-band "Controller + E2E test coverage" row outright (→ ~76), **M-4 (PII masking on the thin hosts)** was closed (→ ~76.5), and **M-3 (login rate limiting on every host)** with it (→ ~77). Numerically past the gate, but the "defensible to deploy" **green** state still needs **H-6 rolled out to the remaining write services** and **H-3 (git + CI)** — neither of which a score can substitute for.

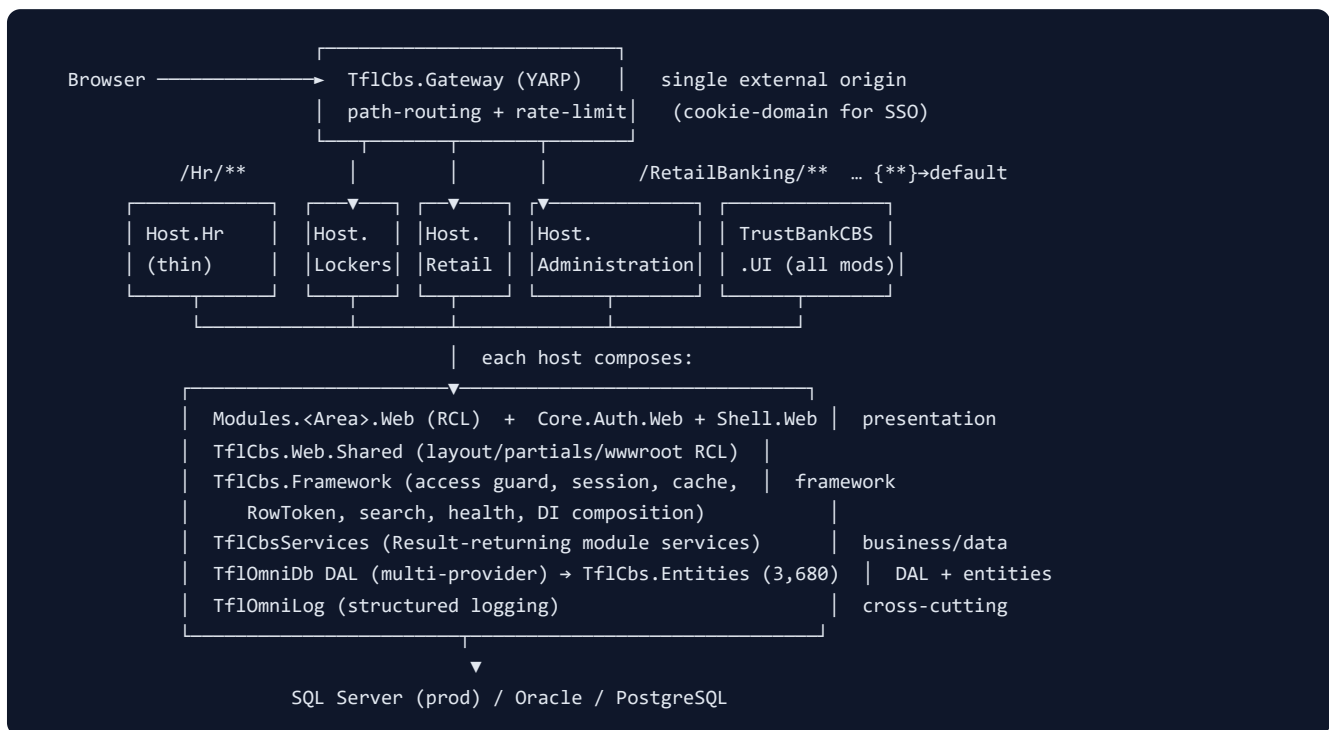
**2026-07-31 — M-3 closed: login rate limiting on every host, ~76.5 → ~77.** The ~90-band row "*Login-specific rate limiting on all hosts*" is ✅ **done**, and like M-4 the finding was **two gaps reported as one**. "Absent on the direct host" is the half everyone reads; the other half is that the gateway's limiter — the one that *was* present — is **volumetric, not credential-specific**: 600 requests/60 s per IP over all traffic permits ~600 password guesses a minute, which is no brute-force control at all. So the single-host shapes had nothing, and the multi-host shape had something that wouldn't trip. **Fix:** a `cbcs-login` policy registered in `AddCbsFramework` with `UseRateLimiter()` inserted **first** inside `UseCbsFramework()` — ahead of session load, identity-cookie decryption and any DB round-trip, so a throttled attempt is refused at the cheapest possible point. The two credential-accepting POSTs ( `/Account/Login` , `/Account/ChangePassword` ) opt in via `[EnableRateLimiting]` , and because `AccountController` ships in `Tf1Cbs.Core.Authentication.Web` — an application part in **all five hosts** — one attribute covers every deployment shape rather than five copies that can drift. Partition is **client IP + request path** (a burst on login cannot exhaust change-password's budget), default **10 / 60 s** via `Security.LoginRateLimit` , rejection **429 + Retry-After** logged under the `Security` category. Two deliberate limits, stated rather than papered over: the **per-username** dimension stays with the DB lockout ( `MAXIMUMLOGINATTEMPT` ), because partitioning on the posted username needs a synchronous form-body read that Kestrel disables by default; and there is **no response body** on the 429, because the middleware owns the status code around `OnRejected` and writing a body risks starting the response before it is set. Config that is *off* still **registers** the policy as a no-limiter — an unregistered policy name is a request-time 500 on the login page, so a flag must not be able to break sign-in — and a zero/negative size is a **startup error**, never a silent "off". **The prerequisite was closed the same day, and it was the more interesting half.** The partition is only per-client if the gateway's `X-Forwarded-For` is trusted, and the Docker multi-host stack shipped with trust **commented out** — not by oversight but because `UseCbsForwardedHeaders` read `KnownProxies` (exact IPs) only, while a Compose service's IP is reassigned on every `up` . Untrusted, every backend sees the *gateway* as the client, which

collapses three controls at once: the new limiter throttles the whole bank as one bucket, `b_LoginPolicy.RemoteHostLoginAttempt` counts everyone's failures against one row, and request logs name the gateway as the caller. So the framework gained CIDR `KnownNetworks` support (feeding `KnownIPNetworks` — the `KnownNetworks` property is obsolete in .NET 10), `compose.multi.yaml` now trusts the bridge pool and `compose.multi.https.yaml` tightens that back to the single static gateway IP, and **a malformed entry in either list now fails the host at startup** instead of being silently skipped — the old `TryParse` -and-ignore left a typo'd address reading as a trust list that wasn't in force, with symptoms pointing elsewhere entirely. Pinned by **25 tests** (9 `LoginRateLimitTests` + 12 `ForwardedProxyTrustTests` + 4 `UntrustedForwardedHeaderWarningTests`), seven of which boot the real host on purpose: the parser unit tests would all still pass if the config key were renamed, and the production symptom of that is a silently untrusted gateway, not a crash. One test earns its place for a different reason — the first draft's `ConfigureAppConfiguration` override never reached the framework's eager config read, so the throttling tests passed against the shipped budget instead of the pinned one; a fixture guard now fails loudly if that recurs. Because the whole failure mode is *invisible* — nothing throws, every page renders — `UseCbsForwardedHeaders` also gained a **detector**: one `Security` -category warning per host start when an `X-Forwarded-For` arrives and is discarded as untrusted (the header still standing with no `X-Original-For`, which is the marker the framework middleware writes for what it consumed). Silent when correct and when no proxy exists, and it names both the fix and what is degraded meanwhile; 4 tests, which need an `IStartupFilter` to stamp a non-loopback peer because `TestServer`'s null `RemoteIpAddress` makes ASP.NET skip the trust check entirely. ☐ Not covered: IIS farms still pin `KnownProxies` by hand — now *detectable* rather than silent, but not enforced (`deploy-cbs-iis.ps1` prints the reminder and what breaks without it) — and the gateway keeps its volumetric limiter as a separate edge layer. **2026-07-31 — M-4 closed: PII masking now applies on every host, ~76 → ~76.5**. The ~90-band row "*PII masking shared to thin hosts*" is ☒ **done**, and the finding turned out to be **worse than M-4 described**. The review recorded it as "masking would not apply on those hosts"; the actual behaviour was more insidious. `MaskingOptions` defaults `Keys` to the banking PII/secret list but defaults `Patterns` to **empty**, so the four thin hosts were not running unmasked — they were running **half-masked**: property-name redaction worked, and **value-regex redaction (PAN / Aadhaar sitting inside a free-text message) silently did not**. Nothing threw, nothing logged, and §3's own strength claim ("recursive PII/secret masking ... wired into every host") read as true because the *enricher* was indeed wired in every host — only its config was not. A config-shaped gap that presents as a working feature is exactly the class of defect a review is supposed to catch, and this one was under-stated. **Fix**: the block was extracted to a canonical `TfLCbs.Host.Main/logmasking.json`, **deleted** from `appsettings.json` so no second copy exists, linked into all four thin hosts (the `route takeover.json` pattern), and loaded in each `Program.cs` before `ConfigureTfLLogging()` — from `AppContext.BaseDirectory`, since a linked file is absent from the content root under `dotnet run`. Loaded **optional: false**: a missing file would degrade to half-masked logging with nothing to notice, so the host now refuses to start instead. Each host re-adds `AddEnvironmentVariables()` afterwards, because `AddJsonFile` *appends* a provider and would otherwise shadow `TfLLog__Masking__` set in `compose` or an IIS `web.config`. Held in place by **LogMaskingConfigTests** (4 facts: the canonical file defines both `Keys` and non-empty `Patterns`; every `Sdk.Web` host that builds a `TfLOmniLog` pipeline ships it, loads it non-optionally before the pipeline, and re-adds the env provider; no host `appsettings.json` re-declares the section) — **verified by mutation**, i.e. both regressions were reintroduced and confirmed to fail the suite. The full **+0.5** is taken because the fix ships with the build regardless of CI; the guard's value is what H-3 still discounts. Two caveats keep this from being "PII in logs is solved": **M-5** (`Database:LogParameterValues` can log parameter values) is untouched, and nothing asserts end-to-end that a PAN written through a thin host's real log file comes out redacted — the *enricher* and the config delivery are each tested, their join is not. **2026-07-30 — the test pyramid's top two tiers landed: Testability 5 → 7, overall ~75 → ~76**. The ~90-band row "Controller + end-to-end (Playwright) test coverage" is now ☒ **done in both halves**: `TfLCbs.IntegrationTests` (2026-07-29, 23 tests) boots the real `Program` pipeline in-process so middleware **order** is what is under test, and `TfLCbs.E2E` (2026-07-30, 80 tests, exit 0) drives a real browser. Together they close the "no controller/E2E tests" dock on Testability outright. The cell stops at **7**, not the 8 the plan projected, because the other two docks are untouched — the **DAL is still not mockable** (`DataAccess` is sealed with no `IDataAccess`) and both new suites still depend on a **live database** for their authenticated half — and because **H-3 (CI) is not started**, so nothing runs any of this automatically; a suite no pipeline executes catches regressions only when someone remembers to look. For the same reason the row's **+1.5** is banked as **~+1** on the holistic number rather than taken in full. Three real defects were found by the browser tier, each pinned with `test.fail()` (green suite, documented bug, unexpected-pass alarm on fix) and now carried as **risk rows 22–24** in §12: a signed identity cookie whose session has closed causes an **infinite /Account/Login** ⇌ **/Modules redirect loop** with no way back to the login form (the multi-host SSO shape exactly); `cbs-account-picker.js` **undoes Model.Disabled at runtime**, though this is **latent rather than live** — the only production consumer, `AccHoldingAmount`, sets `Disabled` only in edit mode where the account is populated, which takes the safe `Lock()` branch; and the component showcase wires `cLearnTargets` on the child picker, so the reference demo developers copy from is backwards. A fourth finding came from the

work rather than the tests and is **row 21**: a login attempt on a dormant account **deactivates it** ( `a_User.STATUS = 3` ) with no recovery path short of a `DBA UPDATE` — it happened twice while choosing a test login. Evidence: [TfLCbs.E2E/README.md](#) . **2026-07-30 — account-list performance work: real gain, no score movement (holds at ~75)**. The account picker was converted to a single server-side join: **24 round-trips** → **1**, ~2× faster at every branch size, equivalence verified on SQL Server and Oracle. It is recorded as **partial** against finding #10 and does **not** lift the Performance cell, because that cell is docked for "load-all patterns, no caching, no retry"\* and all three remain true. Two things are worth carrying forward from the measurement rather than the code: **(a)** DB-side paging — the fix this row originally prescribed — was measured as a **3.6–11× regression** on 54 of 55 branches and is blocked on a DBA index, not on coding effort; **(b)** the same exercise found that three-provider portability is **unproven on PostgreSQL** ( `SqlQuery.From<TEntity>` emits table names unquoted, which PostgreSQL folds to lower case, affecting every `SqlQuery` caller ) — a pre-existing gap now documented, and a candidate dock against Database Design if it is not closed. Evidence: [docs/perf/AccountList-baseline-2026-07-30.md](#) .

## 2. Architecture Overview

### 2.1 Topology



### 2.2 Layering (verified acyclic)

`TfLOmniLog` → `TfLCbsServices` → `TfLCbs.Framework` → `TfLCbs.Web.Shared` → `Modules..Web` → `Host`. No module→module references at the project level (enforced by `NetArchTest`). This is a clean dependency spine.

### 2.3 Key architectural choices

- **Horizontal split**: `TfLCbs.Framework` (reusable web plumbing) ⊥ screen code, compiler-enforced + arch-tested.
- **Modular monolith**: business layer sliced into per-domain module folders ( `General` , `HR` , `RetailBanking` , `Lockers` , `Clearing` , `Accounts` , `Administration` ) with `ICbsModule` self-registration and config gating ( `Modules:Enabled` ). One process, one DB in steady state — the doc explicitly warns against drifting into microservices.
- **Multi-host as a deployment shape, not a distributed system**: the same assemblies can be split behind a gateway for isolation; SSO works via a shared `DataProtection` key ring + a cross-host auth cookie.

- **Reusable UI components:** record picker, account picker, date picker, search modal — vanilla-JS, config-driven, server-side paged.
  - **Capability tokens:** opaque, DataProtection-encrypted, single-use `RowToken`s replace raw PKs in the UI.
- 

### 3. Strengths (what senior architects would praise)

---

1. **Framework layer is genuinely excellent.** 48 files, largest 281 lines, zero god classes, zero utility dumping grounds, all interfaces 1–4 members (ISP respected), no captive dependencies (middlewares method-inject scoped services — the correct pattern), correct `async / ConfigureAwait(false)` hygiene. This is the strongest part of the codebase.
  2. **Services layer discipline.** Every public method returns `Result / Result<T>`; no exceptions cross the boundary; `CancellationToken` threaded end-to-end; **no** sync-over-async anywhere; real `ExecuteInTransactionAsync` unit-of-work wrapping multi-step money/maker-checker operations; parameterized SQL throughout (no injection found in production code).
  3. **Fail-closed access model.** `CbsAccessMiddleware` denies by default; unknown menu → `/AccessDenied`; menu-load error → empty menu; server-side URL-based menu authorization from a `HashSet.Contains` (0 DB hits per request in the single-host steady state).
  4. **Strong client-security defaults.** XSS-safe rendering ( `td.textContent` , no user data into `innerHTML` ), overposting defense via hand-written Form DTOs + `[Bind(Prefix="Form")]` + server-side token-derived PKs, session-fixation handled correctly (session re-mint on login), open-redirect guard on `returnUrl` .
  5. **Production-grade structured logging** ( `Tf10mniLog` ): categories, correlation IDs, recursive PII/secret masking (Password/Pin/Otp/AccountNo/CardNo/Cvv/Pan), buffered async SQL sink that never throws, audit trail with before/after. Wired into every host. *(Correction, 2026-07-31: "wired into every host" was true of the enricher but **not** of its config — the regex half of masking was configured on the default host only, which is finding M-4. The claim is true as written since M-4 was closed; before that it over-stated the control, and the way it over-stated it — a feature that is present, half-configured, and silent about the difference — is worth remembering when reading any other "wired everywhere" claim in this review.)*
  6. **Mature health-check split:** `/health` (liveness, no dependency checks) vs `/health/ready` (provider-aware DB probe), wired into all deploy shapes.
  7. **Reference cache** ( `IReferenceCache` ): generation-token O(1) flush, per-key stampede guard, **fail-open** (never throws, falls back to loader), Redis-optional. Well-engineered.
  8. **Documentation is exceptional** for a codebase this age: 29 Markdown docs with generated HTML twins, architecture decision records, a costed migration estimate (~10,550 person-days), deployment runbooks with troubleshooting tables. Agent-maintained to stay current.
  9. **Modular-monolith boundaries are arch-tested**, including a DI-graph resolvability check that turns a missing registration into a test failure — an unusually good control.
- 

### 4. Weaknesses (ranked)

---

1. **Security hardening is deferred, not done** — auth bypass, reversible passwords, no CSRF, no security headers, no login lockout wired at the MVC layer, committed prod secrets. (§7)
2. **No engineering safety net** — not a git repo, no CI/CD, no IaC, no automated test gate; tests need a live DB and hard-code the `sa` password. (§11, §12)
3. **Concurrency correctness** — no optimistic concurrency/rowversion anywhere; read-modify-write lost updates; `MAX+1` id generation races mitigated only by a unique-index-dependent retry. (§8)
4. **Scale ceiling in the session model** — server-side session lives in single-node `IMemoryCache` (a `TODO` in code), so multi-host relies on per-request DB rehydration and cannot horizontally scale a single host without a distributed store. (§6)
5. **In-memory data patterns** — pervasive `GetAll()` -then-filter/sort/page in memory for list screens; on large transactional tables this materializes a full branch table per request. (§8) *(Note: the newer generic search endpoint pages at the DB — but only for SQL Server; see §10.)*

6. **DIP/build-hygiene leaks** — Framework `ProjectReference` s the concrete `Tf1CbsServices` assembly (abstractions not extracted); bare-DLL `HintPath` s point at **Debug** binaries in an out-of-solution `_Archive` path, so no Release closure exists and there's no build-order edge for `Tf1Cbs.Entities` . (§11)
7. **Observability** —  **instrumentation done**: OpenTelemetry traces + metrics + the `Tf1OmniDb DAL` `ActivitySource` (Oracle-inclusive) + `log`↔`trace` correlation, config-gated; **gateway**→**host**→**DB proven end-to-end**. Remaining is the ops half — prod collector topology, curated dashboards, SLO/alerting, logs→Loki. (§12)
8. **Operational maturity** — no DB migration tooling (manual DDL), no DR/HA design, `sql/` folder nearly empty, `node_modules` committed under `docs/` , one stale compose file. (§12)
9. **Anemic domain / primitive obsession** — money is raw `decimal` , accounts are `int / string` ; all logic is transaction-script in services; no aggregates/value objects/domain events. Defensible for a faithful port, but zero domain richness. (§8)

## 5. Architecture Smells

| Smell                                         | Present?                  | Evidence / notes                                                                                                                                                                                                                                                          |
|-----------------------------------------------|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| God class / god service / god repository      | <b>No</b><br>(production) | Framework max 281 lines; services max 492 ( <code>LockerTypeService</code> ). <i>Watch</i> : the excluded <code>Tf1Cbs.Lab</code> staging project is 16× larger (67k LoC) and is where god services will first appear ( <code>Payments/PmbyPolicyService.cs:773</code> ). |
| Circular dependencies                         | <b>No</b>                 | Verified acyclic; no module→module edges.                                                                                                                                                                                                                                 |
| Tight coupling                                | Partial                   | Framework→concrete <code>Tf1CbsServices</code> (DIP leak); UI models carry DOM selectors as data (leaky abstraction between C# and <code>.cshtml</code> ).                                                                                                                |
| Anemic domain model                           | <b>Yes (by design)</b>    | 3,680 all-nullable UPPERCASE DB-mirror entities; logic in services.                                                                                                                                                                                                       |
| Primitive obsession                           | <b>Yes</b>                | Money = <code>decimal</code> , account = <code>int / string</code> ; no <code>Money / AccountNumber</code> types.                                                                                                                                                         |
| Shotgun surgery                               | Emerging                  | Pipeline composition copy-pasted across 5 host <code>Program.cs</code> files; a cross-cutting change touches all 5.                                                                                                                                                       |
| Duplicate logic                               | <b>Yes</b>                | <code>IsDuplicate / IsForeignKey / Val / Has / Sort / Page / CustomerName</code> helpers duplicated across ~10 services (~40 occurrences).                                                                                                                                |
| Leaky abstractions                            | Yes                       | <code>SearchDescriptor / AccountPickerModel</code> embed client DOM ids; <code>DataAccess</code> registered "Scoped" but returns a cached shared instance.                                                                                                                |
| Utility dumping ground                        | <b>No</b>                 | No <code>Utils.cs / Helpers.cs</code> grab-bags.                                                                                                                                                                                                                          |
| Large interfaces                              | <b>No</b>                 | Max 4 members.                                                                                                                                                                                                                                                            |
| Fat controllers                               | <b>No</b>                 | Largest (355 lines) hosts two screens; logic is in services.                                                                                                                                                                                                              |
| Service locator                               | Minor                     | <code>RequestServices.GetService</code> for <i>optional</i> ports (intentional) + <code>Notify</code> static extensions.                                                                                                                                                  |
| Cyclic references / inappropriate inheritance | <b>No</b>                 | —                                                                                                                                                                                                                                                                         |
| Feature envy                                  | Minor                     | Some cross-field UI validation lives in controllers that arguably belongs in services ( <code>LockerTypeController.ValidateWrite</code> ).                                                                                                                                |



## 6. Scalability Analysis

**Test method:** reasoning from architecture + measured per-request cost, not load testing (no load harness exists).

| Users<br>(concurrent-ish) | Verdict                | Where it strains                                                                                                                                                                                                                                                                                                                                                                                          |
|---------------------------|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 100                       | ✅ Fine                 | Single host, warm session = 0 DB hits/request for the access guard. Comfortable.                                                                                                                                                                                                                                                                                                                          |
| 1,000                     | ✅ Mostly fine          | In-memory list/filter on large tables (accounts/holds/employees) starts to cost CPU + allocations per search. Reference data re-read per request (no service-layer cache).                                                                                                                                                                                                                                |
| 10,000                    | ⚠️ Strains             | (a) Full-table materialization per search on transactional tables → GC pressure, LOH risk on big result sets. (b) Per-request <code>IsSessionActiveAsync</code> + revocation DB/cache round-trips when auth module wired. (c) Single-node session store becomes a memory-pressure eviction risk → silent session loss + rehydration storms.                                                               |
| 100,000                   | ❌ Fails without rework | Single-node <code>IMemoryCache</code> session is the wall. Horizontal scale-out requires either a distributed session store or gateway <b>session affinity</b> (neither present; <code>SessionAffinity</code> not configured on YARP). Every non-sticky request to a fresh backend triggers a <b>DB menu reload</b> . In-memory paging paths saturate DB + app memory.                                    |
| 1,000,000                 | ❌ Not designed for it  | Would require: distributed session/cache (Redis), DB read replicas + CQRS read models, DB-side paging on all providers, connection-pool + transient-retry tuning, per-module horizontal scale behind the gateway with affinity, and a caching tier for reference data. The modular-monolith <i>can</i> be scaled per-module behind YARP, but the shared single DB and in-memory patterns are the ceiling. |

**Bottleneck ranking:** (1) single-node session store, (2) load-all-then-filter on large tables (*⚡ partial — the account picker's 24 round-trips are now 1 and it is ~2× faster, but the load-all remains and 6 services are untouched*), (3) shared single database with no read-replica/CQRS story, (4) per-request auth DB round-trips, (5) no service-layer caching of read-mostly reference data (*infra ready — `IReferenceCache` is distributed + fail-open and proven by `BankVars`; which masters to cache is a deferred **decision**, not missing engineering*), (6) no transient-fault retry (Polly) so DB blips cascade to user errors (*backlogged 2026-07-30; seam settled at the DAL chokepoint, gated on agreeing write-idempotency rules*).

**Highest-leverage fixes:** distributed session (Redis) + gateway session affinity; push filtering/sorting/paging into the DB for the high-volume list screens (provider-dialected); cache reference data via the existing `IReferenceCache` — **infra already built, only the scope decision is outstanding**; add Polly transient-retry on DB calls — **backlogged, gated on idempotency classification** (see `BACKLOG.md`).

## 7. Security Analysis

Severity is estimated for a **core-banking** context. Positive controls are listed too — several are genuinely good and worth preserving.

### Critical

- **C-1 — Authentication bypass via `MFA_AD_LOGIN_ENABLED`** . `AuthenticationService.cs:299`: `if (storedPassword != password && mfaAdLoginEnabled == 0)` . When the `MFA_AD_LOGIN_ENABLED` bank variable is non-zero, the password mismatch branch never fires, `error / isLoginFailed` stay unset, and execution falls through to success (line 368+). **No AD/alternative authentication is implemented anywhere in the method** — the flag gates *out* the password check without gating *in* a replacement. Any password authenticates a valid username. Verified directly against source. **Fix:** never allow the success path when the primary credential is unverified; if AD auth is intended, implement and require it, otherwise remove the flag branch.

- **C-2 — Reversible password storage.** [AuthenticationService.cs:296-299](#): submitted password is `Tf1SecurityCrypto.Encrypt`-ed and compared as a Latin1 string to a recoverable `varbinary`. No `bcrypt/PBKDF2/Argon2`, no per-user salt. A DB compromise = mass plaintext password recovery (and credential-stuffing against other systems). Legacy-parity constraint, but unacceptable at go-live. **Fix:** migrate to a salted adaptive hash (`Argon2id/PBKDF2`) with a transparent rehash-on-login upgrade path.

## High

- **H-1 — No CSRF protection anywhere.** Zero `[ValidateAntiForgeryToken]` / `AutoValidateAntiforgeryToken` / `AddAntiforgery` across ~30 POST actions in 12 controllers (Login, Logout, all Save/Update/Delete/Authorize, the dev DB-switch). Confirmed independently by two review passes. Single-use `RowToken`s partially mitigate *record-scoped* writes but do nothing for Save (new record), Login, or Logout. The app *emits* antiforgery cookies but never validates them. **Fix:** global `AutoValidateAntiforgeryToken + @Html.AntiForgeryToken()`; inject the token header on the `fetch`-based search/JSON endpoints.
- **H-2 — Committed production DB credentials +** `sa`. `Base appsettings.json` (loaded in **all** environments) in `Tf1Cbs.Host.Main` and every `Tf1Cbs.Host.*` carries `User Id=sa;Password=sql@2019;TrustServerCertificate=true`. `Sysadmin` principal, no least-privilege, and `TrustServerCertificate=true` disables TLS validation to SQL Server (MITM). **Fix:** move secrets to a secret store / `user-secrets` / `env`; use a least-privilege app login; issue a real SQL TLS cert.
- **H-3 — No source control / CI gate** (see §12) means none of the above is caught by an automated pipeline before deploy.
- **H-4 — Latent fail-open on middleware ordering.**  **FIXED (2026-07-18).** [CbsAccessMiddleware.cs:48](#): if `GetEndpoint()` is null the guard passes. If `UseCbsFramework()` is ever ordered before `UseRouting()`, **every** request has a null endpoint → the entire fail-closed guard is silently skipped. Was protected only by a doc comment. **Fixed:** `UseCbsFramework()` now calls `EnsureEndpointRoutingRegistered()` as its first line, throwing at startup if routing hasn't run; pinned by 2 tests (`GuardOrderingTests`).

## Medium

- **M-1 — No security headers:**  **FIXED (2026-07-18).** Was: no CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy — clickjacking + MIME-sniffing exposure on an authenticated banking UI. **Fixed:** `UseCbsSecurityHeaders` (framework, first middleware in all 5 hosts) emits all five on every response incl. static files, with a **fully strict enforced CSP** (`script-src / style-src 'self'`, no nonce, no `unsafe-inline`); all inline scripts/handlers/styles were refactored out so nothing is exempted.
- **M-2 — Cookie hardening in committed config:** auth cookie `SecurePolicy=SameAsRequest` (can ride HTTP); session cookie sets `HttpOnly` but not `Secure/SameSite`. Docker overrides fix it; IIS/other deploys must remember to.
- **M-3 — No login-specific / direct-host rate limiting.**  **FIXED (2026-07-31).** Was: rate limiting existed only on the gateway (600/60s per IP, not login-specific) and was absent entirely on the direct `Tf1Cbs.Host.Main` host, so brute-force defense relied solely on the DB lockout policy being configured. **Fixed:** a `cbs-login` policy registered in `AddCbsFramework` and applied by `UseCbsFramework` — so **all 5 hosts** get it by construction, single-host shapes included — partitioned by **client IP + request path**, default **10 attempts / 60 s**, opted into by the two credential-accepting POSTs (`/Account/Login`, `/Account/ChangePassword`) via `[EnableRateLimiting]`. Rejections are **429 + Retry-After**, logged under the `Security` category, and are refused *first* in the pipeline — before session load, cookie decryption or any DB round-trip. Config: `Security:LoginRateLimit (Enabled=false` to disable; a zero/negative value is a startup error, never a silent "off"). Pinned by 9 tests (`LoginRateLimitTests`, incl. a fixture guard that the pinned limit really reaches the framework). **Two limits deliberately kept:** the gateway's global limiter stays (volumetric abuse at the edge), and the DB lockout policy stays the **per-account** control — a middleware limiter cannot partition on the submitted username without a synchronous form-body read, which Kestrel disables by default. **Deployment prerequisite — also closed (2026-07-31).** The partition key is only the real client IP if `ForwardedHeaders` is enabled *and* the gateway is trusted; untrusted, every user shares one partition. The Docker multi-host stack shipped with trust **commented out** because the framework read `KnownProxies` (exact IPs) only and a compose service's IP is dynamic. `UseCbsForwardedHeaders` now also accepts `ForwardedHeaders:KnownNetworks` (CIDR), `compose.multi.yaml` trusts the bridge pool (`172.16.0.0/12` — safe: only the gateway publishes a port), and `compose.multi.https.yaml` tightens that back to the single static gateway IP. A malformed entry in either list is now a **startup failure** rather than being silently skipped. 16 tests (12 `ForwardedProxyTrustTests` + 4 `UntrustedForwardedHeaderWarningTests`), 7 of which boot the real host so neither a config-key rename nor a lost detector can pass unnoticed. A *missing* entry is caught at runtime too: a discarded `X-Forwarded-`



For logs one `Security` warning per host start. ☐ IIS farms still set `KnownProxies` by hand — `deploy-cbs-iis.ps1` prints the reminder and the consequences.

- **M-4 — PII masking config missing on thin hosts.** ☒ **FIXED (2026-07-31).** Was: the `TfLog Masking` block existed in `TfLCbs.Host.Main` but not in the `Host. appsettings`. **The original wording under-stated it** — the effect was not "masking would not apply" but something quieter: `MaskingOptions` defaults `Keys` to the banking PII list and defaults `Patterns` to **empty**, so the thin hosts ran **half-masked** — name-based redaction on, value-regex redaction (PAN/Aadhaar in free text) silently off, with nothing thrown or logged to say so. **Fixed:** the block moved to a canonical `Logmasking.json` (deleted from `appsettings.json`, so there is no second copy to drift), linked into all four thin hosts like `route takeover.json`, loaded from `AppContext.BaseDirectory` before `ConfigureTfLogging()` and **optional: false** so a missing file stops the host instead of degrading it, with `AddEnvironmentVariables()` re-added after (an appended JSON provider would otherwise shadow `TfLog_Masking`). Guarded by `LogMaskingConfigTests` (4 facts, mutation-verified). **Still open in this area: M-5**, and no end-to-end assertion that a PAN survives a real thin-host log file redacted.
- **M-5 — Database:LogParameterValues** can log SQL parameter values (account numbers, balances, PII) at Information level; gated to Dev by config but the switch exists.
- **M-6 — RouteCutover privilege-escalation surface.** ☒ **CLOSED (2026-08-24).** Was: a misconfigured mapping in `route takeover.json` pointing a legacy URL at a *different* screen's route granted that screen's access (`AllowedUrls` derives from node URLs), with no validation. The legacy WebForms app no longer reads the CBS database, so the whole config layer was **deleted** — `RouteCutover`, `RouteCutoverOptions`, `config/route takeover.json` and its wiring in all five hosts — and the new route now lives in `a_Menus.NavigateURL` itself (`0004_menu_routes_cutover.sql`). `MenuService` no longer rewrites anything. **The surface is not eliminated, it is relocated:** a wrong `NavigateURL` still grants the wrong screen. What changed is that it now takes a reviewed, journalled migration rather than an unvalidated config edit that reloads at runtime, and there is one source of truth instead of two that could disagree. ☐ Still no validation that a row's route belongs to that row's screen.
- **M-7 — Thin-host Auth:LoginUrl committed as plain HTTP** — credentials would 302 to an HTTP origin unless overridden.

## Low / Info (positive controls to preserve)

- Session fixation handled (session re-mint on login); logout invalidation thorough (closes log rows, revokes cross-host session, signs out cookie); account/IP **lockout policy exists** in the service; SSO authority-deferral with open-redirect allowlist; RowTokens are AES+HMAC via DataProtection, screen+session-bound, single-use; `SecurityElement.Escape` on stored IP/User-Agent; the one `Html.Raw` serializes server-derived menu JSON (low risk, though the JSON island isn't `</script>`-escaped — tighten it); docker publishes only the gateway port (backends internal-only); ForwardedHeaders defaults to loopback-only trust (remote spoofing blocked unless misconfigured) — *and since 2026-07-31 the opposite error is no longer silent either: a host that **discards** a proxy's X-Forwarded-For because the peer isn't trusted says so once per start in the `Security` log, so the safe default can't quietly cost you per-client rate limiting, per-IP lockout and log attribution.*

**Note on the RowToken cross-host limitation:** RowTokens are bound to the per-host in-memory session GUID, so a token minted on host A fails on host B. In a multi-host jump mid-flow, on-screen row tokens invalidate. Functional/robustness issue rather than a vulnerability, but undocumented.

---

## 8. Performance Analysis

- **N+1: largely avoided.** Related-entity loads are batched with chunked `IN` lists (Oracle-safe  $\leq 500$ ). Good.
- **Load-all-then-filter/sort/page in memory: pervasive** for list screens — `GetAllAsync()` + in-memory LINQ across ~7+ services (`StateService`, `DistrictService`, `TalukaService`, `RoleService`, `ModuleService`, `DiscipActionHistoryService`, `AccountService`). On small lookup tables this is fine; on **accounts/holds/employees** it materializes a full branch table per request → CPU, excessive allocations, and Large Object Heap risk on big pages. The code comments are candid about it.

- **Partially addressed 2026-07-30 — the chattiness, not the load-all.** `AccountService` (the worst case: the account picker) was converted from load-branch-then-rebuild-the-joins-in-memory to **one server-side join** via the dialected `SqlQuery` builder. Round-trips per page view fell from `4 + ceil(distinctClients/500)` — **24** on the largest branch — to **1**, and median latency improved ~2× (330/125/48 ms vs 526/239/70 on 20,480 / 7,516 / 1,392-account branches), overtaking the legacy `pr_b_GetAccountList` it ports.

Verified equivalent on SQL Server **and** Oracle (identical row Totals). **The load-all itself is unchanged** — the branch's result set is still materialized per request, so the CPU/allocation/LOH concern in this bullet stands as written, and the remaining six services are untouched. Measurements: [docs/perf/AccountList-baseline-2026-07-30.md](#).

- **In-memory pagination:** `list.Skip().Take()` after full materialization in 8 services; `Total = list.Count`. *Originally noted counterpoint:* the generic `SearchQueryService` paged at the DB with `OFFSET/FETCH`, but that path was **SQL Server-only**, so the multi-provider promise broke there. **Resolved 2026-07-29 — in the provider direction, not the perf one:** `SearchQueryService` was deleted and its two callers (Locker Type, Disciplinary Action History) converted to `Repository<T>` + in-memory paging, so no framework code assembles SQL and nothing is provider-specific. The trade was made deliberately: **in-memory paging is now universal, so this weakness is broader than when first written** — every list screen materializes its (branch-scoped) set. Fine for the lookup masters converted so far; the accounts/holds/employees concern below is unchanged and still the one to fix, now with no DB-paging precedent left in the codebase to build on. **Update 2026-07-30 — DB-side paging measured and deliberately deferred.** A `SqlQuery` prototype (4 joins + `ORDER BY ... OFFSET/FETCH + COUNT()`) was benchmarked against the account list on the production-scale dev DB and is a **regression on 54 of 55 branches**: 1.15× faster on the largest branch but **3.6× slower on the median and 11× slower on the small one** (715 ms flat vs 196/65 ms). Cause: the paged join full-scans `G_GLOBALCLIENT` — **166,404 logical reads to return 15 rows** — and neither `OPTION (RECOMPILE)`, `OPTION (FAST 15)`, nor paging a derived table first changes it (a forced `LOOP JOIN` is 6.9 s). The legacy proc escapes it only by embedding literals in dynamic SQL. Also established: paging **cannot** run on `B_ACCOUNT` alone — 30 of 1,392 accounts on one branch are dropped by the title join before\* paging, which is what makes `Total` correct. So DB-side paging is blocked on a supporting index on `B_ACCOUNT(ORGELEMENTID, ACCOUNTSTATUSCODE, ACCOUNTNUMBERFORDISPLAY)`, not on code. Evidence: [docs/perf/AccountList-baseline-2026-07-30.md](#).
- **No service-layer caching** of read-mostly reference data (titles, codes, account heads, modules) — re-read from DB every request despite being pulled fully into memory anyway. Obvious `IReferenceCache` candidates.

- **Reframed 2026-07-30 — this is a scoping decision, not missing engineering.** The infrastructure exists and is production-proven: `IReferenceCache` is `IDistributedCache`-backed (in-memory / Redis / SQL Server is a `Cache:Provider` config choice, not a code change), **fail-open** by design (a cache fault falls back to the loader, logs, and throws nothing at the caller), with `IReferenceCatalog` TTLs per category and a `/Bank/ReferenceCache` inspector + eviction screen. Applying it to a master is *wiring*: register a category, wrap the existing loader in `GetOrCreateAsync`, evict on that master's CRUD. **Only BankVars (bank/branch variables) consumes it today, and which masters to cache is deferred by decision, not blocked** — the measured per-request offenders are catalogued in [BACKLOG.md](#) ("Cache-adjacent"): `DiscipActionHistoryService` (`GetAllAsync()` over all of `G_TITLE` + `G_DESIGNATION` per list render), `SearchAccountHeadsAsync` (all 1,695 `G_ACCOUNTHEAD` rows), `LockerTypeService` / `GeneralGrp11Service` (`B_CODE`). The account list's titles/codes/heads no longer qualify — they became a server-side join on 2026-07-30.

- **No transient-fault handling** (Polly/retry/circuit-breaker) on any DB call — a transient SQL/Oracle blip surfaces directly as a user error. Material for Azure SQL / networked DBs.

- **Confirmed still absent and formally backlogged 2026-07-30** (no Polly package in `Directory.Packages.props`, no retry on any DB path) — see [BACKLOG.md](#) → "Resilience — transient-fault handling (Polly)". The implementation seam is settled: one policy at `TfIOmniDb`'s single execution chokepoint `CommandLogger.ExecuteAsync`, the same place `BindByName` and the OTel `ActivitySource` already live, so every provider and call site inherits it. **The open work is idempotency classification, not wiring** — in a core banking system a blindly-retried write can double-post, so the policy needs a transient error-code allowlist, free retry on reads, and writes only where the failure provably preceded commit. Deferred until that classification is agreed.

- **Concurrency / lost updates (High).** No rowversion/optimistic concurrency token anywhere. The standard update pattern (load full row → mutate → `UpdateAsync` rewrites every column) is **last-writer-wins with silent lost updates** under concurrent editors. `ScrollService.CreateAsync` MAX+1 numbering has an acknowledged duplicate-key race mitigated by a **unique-index-dependent** 3× retry — *verify that unique constraint exists in every target DB, or the retry cannot fire*.
  - **Async: excellent.** No sync-over-async in services or hot framework paths (the only `.GetAwaiter().GetResult()` is in the DataProtection XML repo — a synchronous ASP.NET contract, startup-only, documented). No `async void`.
  - **The real money path is not yet migrated.** `AccountService.GetWithdrawableAmountAsync` is a stub; the transaction engine lives only in the excluded `Lab` project. So transaction/concurrency guarantees are proven on holds/CRUD but **unproven on the highest-risk balance-movement path**.
-

## 9. Maintainability Analysis

**Strong.** Single-responsibility files, consistent conventions (PascalCase types, `_camelCase` fields, UPPERCASE entity props by generation), clear namespace/folder organization, dedicated Form DTOs, a well-designed `CbsScreenController` base that centralizes the token lifecycle, and reusable components with safe-default extension points. Documentation is a standout.

**Debt:**

- **5× duplicated host** `Program.cs` (~40 lines each, differ by 2 lines) — extract `builder.AddCbsHost(...)` / `app.UseCbsHost(...)`.
- **~40 duplicated helper methods** across services — extract a shared `ServiceHelpers` /base.
- **Bare-DLL Debug-path references** to `Tf1OmniDb` / `Tf1SecurityCrypto` / `Tf1Cbs.Entities` — fragile, no Release closure, no build-order edge.
- **9 projects share** `RootNamespace=Tf1Cbs.Host.Main` (including the misleadingly-named "Framework") — a namespace-collision surface the team already hit once (Lab got a distinct namespace to avoid CS0433).
- **Stale docs:** `CLAUDE.md` describes a `name="command"` POST-dispatch pattern the migrated screens no longer use (they use per-action `formaction` routes — which is the better pattern; update the doc). `compose.multi.yaml` still references deleted `Misc/Accounts` modules.
- **node\_modules committed** under `docs/migration-estimate/` (~560 files); **empty unreferenced** `_CommonPackages` folder; ~351 junk/backup DB tables mirrored into `Tf1Cbs.Entities` ( `A_ROLEONMENU29072024` , `AAA` , `ABC` ...). Carried-over DB typos faithfully reproduced ( `LASTMODIFIEDON` ).

## 10. Design Pattern Analysis

| Pattern                | Usage                                                                                                                                                         | Assessment                                                                                                                                                   |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Repository             | <code>Repository&lt;T&gt;</code> ( <code>Tf1OmniDb</code> )                                                                                                   | Correct, used consistently. <code>UpdateAsync</code> rewrites all columns (load-first discipline required — a footgun the team documents).                   |
| Unit of Work           | <code>ExecuteInTransactionAsync(IUnitOfWork)</code>                                                                                                           | Correct and idiomatic where used; the money-movement path that would exercise it most isn't migrated yet.                                                    |
| Result / Railway       | <code>Result</code> / <code>Result&lt;T&gt;</code>                                                                                                            | Sound, immutable, ~100% adoption, no boundary exceptions. A model example.                                                                                   |
| Ports & Adapters (DIP) | <code>ISessionValidator</code> / <code>IMenuSource</code> / <code>IBankVariableSource</code> / <code>IBroadcastSource</code><br>+ <code>Null*</code> defaults | Correct intent; leaked by <code>Framework</code> →concrete- <code>Tf1CbsServices</code> project reference (extract an Abstractions assembly).                |
| Strategy               | <code>DatabaseSelector</code> provider switch; per-column match operators                                                                                     | Reasonable. (2026-07-29: <code>SearchColumn.Match</code> is now advisory metadata only — the per-column operator is applied by each screen's search service, |

| Pattern                                                 | Usage                                             | Assessment                                                                                     |
|---------------------------------------------------------|---------------------------------------------------|------------------------------------------------------------------------------------------------|
|                                                         |                                                   | <i>not by shared framework code.)</i>                                                          |
| <b>Factory</b>                                          | DI factory registrations                          | Fine.                                                                                          |
| <b>Capability token</b>                                 | RowToken                                          | Strong crypto design (AES+HMAC, screen/session-bound, single-use).                             |
| <b>Module/Composition</b>                               | ICbsModule + config gating + arch-tested DI graph | Good modular-monolith seam.                                                                    |
| <b>CQRS</b>                                             | Absent                                            | Not needed yet; would become relevant for read-scale (replicas/read models) at 100k+ users.    |
| <b>Mediator</b>                                         | Absent                                            | Acceptable — thin controllers over services don't need MediatR; adding it now would be YAGNI.  |
| <b>Specification</b>                                    | Absent                                            | In-memory LINQ predicates play this role; a spec pattern could unify filter logic if it grows. |
| <b>Builder</b>                                          | SqlQuery.From<>()... fluent builder               | Present in the DAL usage.                                                                      |
| <b>Domain events / Aggregates / Value objects (DDD)</b> | Absent                                            | Anemic-by-design; primitive obsession on money/account.                                        |

**KISS/DRY/YAGNI/SOLID:** KISS is well-served (thin controllers, no gratuitous abstraction). DRY is violated in host bootstrap (*service helpers: resolved 2026-07-29 — extracted to ServiceQuery / DbErrors in TflCbs.Abstractions and locked by an arch test; see §11*). YAGNI is mostly respected (no speculative MediatR/CQRS) — the one over-engineering candidate is the **multi-provider DAL** (Oracle/PG support, and per-method perf harnesses) if SQL Server is the only production target. (*Amended 2026-07-29: the "DB-side search paging is SQL-Server-only, so multi-provider isn't fully real" evidence no longer holds — that path was deleted, and the service layer is now provider-neutral throughout. The right-sizing question in §14.7 stands on its own merits.*) SOLID scored in §13.

## 11. Project-by-Project Review

- **TflCbs.Entities** (3,680 generated files, 15.6 MB DLL) — faithful 1:1 DB mirror, zero hand edits (safe to regenerate), but ~10% is junk/backup-table noise and carries DB typos. Referenced by **bare Debug-path DLL**, creating build-order fragility (no MSBuild edge; relies on incidental slnx ordering). Recommend a table allowlist for generation.
- **TflCbs.Services** (35 files, ~4,100 LoC) — the crown jewel of discipline (Result, async, transactions, parameterized SQL). Weaknesses: in-memory paging, ~~duplicated helpers~~, no caching, no concurrency tokens. Folder structure matches the modular-monolith doc. (**Duplicated helpers resolved 2026-07-29:** *the ~37 byte-identical private members across 8 services — Has / Eq / Val / Paged / IsDuplicate / IsForeignKey + the page-size consts — were extracted to ServiceQuery / DbErrors in TflCbs.Abstractions and consumed via using static, so no call site changed. Placed in Abstractions rather than TflCbs.Services because that assembly dissolves under the modular-monolith plan. SharedServiceHelperTests now fails the build on a private re-declaration — mutation-verified — since two of the copies had been added after this finding was first written.*)

- **TfICbs.Lab / .Lab.Demo** (excluded from build) — 67k LoC staging ground, 16× the production layer; a 406 KB single-file Roslyn promotion driver. Where god-service risk lives; fine as a staging area but keep it out of the shipped closure (it is).
- **TfICbs.Framework** (48 files) — excellent (see §3). Fix: extract Abstractions assembly (DIP), fix bare-DLL refs, add an ordering assertion for the access guard, audit denied access attempts (a `TODO`), prune the never-pruned `_gates` semaphore dictionary.
- **TfICbs.Web.Shared** — clean RCL; XSS-safe; one JSON island to tighten; ships unused jQuery/validation (~13k lines dead weight — prune).
- **\*Modules.Web\*** (Bank/Hr/Lockers/RetailBanking/Administration) — thin, arch-boundaried, no cross-module refs. Bank is backed by the General service (a documented naming footgun). ~9 functional screens migrated + 2 stubs.
- **Core.Authentication(.Web)** — login/logout, SSO deferral, lockout policy. Contains C-1/C-2. Otherwise solid session/logout handling.
- **Core.Shell.Web** — Home/Modules/Error/AccessDenied infra screens.
- **TfICbs.Gateway** (YARP, 38 lines) — genuinely thin, config-driven routing, per-IP rate limit, own health path. No session affinity (scale concern). Trust model is network-only.
- **TfICbs.Host.\*** (4 thin hosts, 62 lines each) — near-identical; DRY debt. Correctly handle the linked-config `AppContext.BaseDirectory` issue.
- **TfICbs.Host.Main** — full host + composition root; owns canonical `appsettings.json`.
- **TfICbs.Tests** (15 files, 105 facts) — integration tests against a live DB, **no mocks** (DAL not behind an interface), thin value assertions (can't seed data), **hard-codes the sa password**, collapse to ~0 cases without infra. Real edge coverage only on failure paths.
- **TfICbs.Demo** — 739-line manual cross-provider smoke harness; agent-synced; useful now, dead weight post-cutover.
- **TfICbs.OmniLog(.Tests/.Demo)** — production-grade logging library with 20 real unit tests. A genuine asset.
- **TfICbs.ArchTests** (22 passing) — enforces `framework↓screen` + `module↓module` + DI-graph resolvability. Good, though allowlist-style (new namespaces silently unguarded); redundant per its own docs now that the split is compiler-enforced.
- **TfICbs.IntegrationTests** (*added 2026-07-29; 23 tests, ~2s*) — the controller/HTTP tier. `WebApplicationFactory` / `TestServer` boots the real `Program`, so middleware **order** is the subject, not a directly-called controller. The guard/antiforgery half needs **no database** (an anonymous request short-circuits before any service resolves) and is CI-ready as-is; the authenticated half mints a `CbsAuth` cookie with the host's own key ring so authorization is decided by real `a_UserMenu` / `a_Menus` data, and skips without a connection string. Read-only. One seam stubbed ( `ISessionValidator` ), and that seam's unstubbed behaviour is itself covered.
- **TfICbs.E2E** (*added 2026-07-30; 80 tests, exit 0 — 69 pass, 11 skip, 3 pinned defects*) — the browser tier. TypeScript + Playwright, outside the `.slnx`, **no app source changes required**. Split by identity: `guest` needs neither credentials nor a database; `app` shares one login. Reusable-component coverage runs against the Development-gated `/Dev/Components` showcase (canned in-memory data, `TempData`-only notifications), so pickers, the search modal and the notification split are covered **without touching the bank database**. Real-screen coverage is self-calibrating against menu rights and skips with a reason rather than pretending. Notable rigour: the CSP spec injects an inline script and asserts it is **refused**, so those assertions cannot pass vacuously.

## 12. Risk Matrix

| # | Issue                                         | Severity                                                                                                                    | Impact                                          | Recommendation                                                                                           |
|---|-----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| 1 | <code>MFA_AD_LOGIN_ENABLED</code> auth bypass | <b>Critical</b> · <br><b>FIXED</b> (C-1) | Any password logs in a valid user when flag set | ~~Block success on unverified credential~~ — done: fail-closed guard + pinned test                       |
| 2 | Reversible password encryption                | <b>Critical</b> · <br><b>FIXED</b> (C-2) | DB compromise → mass plaintext recovery         | ~~Salted PBKDF2 + rehash~~ — done: PBKDF2 primitive, all users migrated, login/change-password verify it |

| #  | Issue                                                    | Severity                                                                                                                   | Impact                                                               | Recommendation                                                                                                                                                                                                                                                                                                                                                                                                             |
|----|----------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 3  | No CSRF on any POST                                      | High ·  <b>FIXED</b> (H-1)                | Forged Save/Login/Logout/DB-switch                                   | ~~Global<br>AutoValidateAntiforgeryToken ~~ —<br>done: registered in AddCbsFramework +<br>AJAX token header                                                                                                                                                                                                                                                                                                                |
| 4  | Committed sa prod creds +<br>TrustServerCertificate=true | High ·  <b>MOSTLY</b> (H-2)               | Credential leak, MITM, no least-<br>privilege                        | Secrets externalized (out of committed<br>config) · <b>remaining: rotate sa , least-<br/>priv login, real TLS cert</b>                                                                                                                                                                                                                                                                                                     |
| 5  | No git / CI / IaC                                        | High                                                                                                                       | No history, no automated gate,<br>unrepeatable infra                 | Init repo; pipeline (build+test+scan); IaC<br>for infra                                                                                                                                                                                                                                                                                                                                                                    |
| 6  | No optimistic concurrency                                | High ·  <b>PATTERN ON<br/>STATE</b> (H-6) | Silent lost updates on banking writes                                | Reference impl on State master —<br>TfIOmniDb-native row-version<br>( [DbColumn(IsRowVersion=true)] →<br>auto-increment + WHERE guard +<br>ConcurrencyException ; conflict test<br>passes on dev DB); rollout to remaining<br>write services pending                                                                                                                                                                       |
| 7  | Latent fail-open on guard<br>ordering                    | High (latent) ·  <b>FIXED</b> (H-4)       | Total access-control bypass on<br>misordering                        | ~~Startup assertion routing ran~~ —<br>done:<br>EnsureEndpointRoutingRegistered()<br>+ 2 pinned tests                                                                                                                                                                                                                                                                                                                      |
| 8  | No security headers                                      | Medium ·  <b>FIXED</b> (M-1)              | Clickjacking, MIME-sniffing                                          | ~~Add CSP/X-Frame-Options/X-<br>Content-Type-Options middleware~~<br>— done: UseCbsSecurityHeaders , fully<br>strict CSP + 4 companion headers                                                                                                                                                                                                                                                                             |
| 9  | Single-node in-memory session                            | Medium                                                                                                                     | Scale ceiling + session loss under<br>pressure                       | Distributed session (Redis) + gateway<br>affinity                                                                                                                                                                                                                                                                                                                                                                          |
| 10 | Load-all-then-filter on large<br>tables                  | Medium ·  <b>PARTIAL</b>                | CPU/memory/LOH at scale                                              | Account picker converted to <b>one<br/>server-side join</b> (24→1 round-trips, ~2×<br>faster, SQL Server + Oracle verified).<br>Load-all itself remains, 6 services<br>untouched. <b>DB-side paging measured<br/>as a regression</b> (3.6–11× slower; the<br>paged join full-scans G_GLOBALCLIENT ,<br>166k reads for 15 rows) → blocked on<br>an index, not code. See<br>docs/perf/AccountList-baseline-<br>2026-07-30.md |
| 11 | No metrics/tracing/APM                                   | Medium ·  <b>INSTRUMENTED</b>           | Blind in production                                                  | ~~OpenTelemetry traces+metrics~~ —<br>done: AddCbsObservability (traces<br>incl. DAL/Oracle spans, RED + runtime<br>metrics, correlated; gateway→host→DB<br>proven). Remaining: dashboards / SLO<br>alerting / logs→Loki                                                                                                                                                                                                   |
| 12 | No DB migration tooling                                  | Medium ·  <b>FIXED</b>                  | Unrepeatable, un-versioned schema<br>changes for a regulated cutover | ~~DbUp/EF/Flyway; version DDL~~ —<br>done: TfICbs.Tools.DbMigrator<br>(DbUp), versioned DDL in<br>Migrations/<provider>/NNNN_*.sql ,<br>CbsSchemaVersions journal,                                                                                                                                                                                                                                                         |



| #  | Issue                                                                | Severity                                        | Impact                                                                                                                                                                               | Recommendation                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----|----------------------------------------------------------------------|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                      |                                                 |                                                                                                                                                                                      | status / preview / upgrade / baseline ;<br>deploy-script check + Docker migrate<br>profile. Remaining: a 0000 legacy-<br>schema baseline; PostgreSQL scripts<br>unrun on a live instance (SQL Server +<br>Oracle verified)                                                                                                                                                                                                                                                                                                                                             |
| 13 | No DR/HA posture                                                     | Medium                                          | No RTO/RPO, single-replica in-<br>memory sessions                                                                                                                                    | DR runbook, DB HA (Always On),<br>distributed session                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| 14 | No transient-fault retry                                             | Medium · 📄<br><b>BACKLOGGED</b><br>(2026-07-30) | DB blips → user errors                                                                                                                                                               | Polly retry + circuit breaker at<br>TfLOmniDb's single<br>CommandLogger.ExecuteAsync<br>chokepoint (one policy, all providers).<br>Confirmed absent; <b>gated on write-<br/>idempotency classification</b> — a<br>blindly-retried write can double-post.<br>BACKLOG.md → "Resilience"                                                                                                                                                                                                                                                                                  |
| 15 | Bare-DLL Debug-path refs / no<br>Release closure                     | Medium                                          | Release ships Debug binaries; fragile<br>builds                                                                                                                                      | ProjectReference or NuGet; Release<br>paths; build-order edge                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| 16 | Framework→concrete services<br>(DIP leak)                            | Medium                                          | Architecture inversion                                                                                                                                                               | Extract *.Abstractions assembly                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| 17 | Login rate limiting absent on<br>direct host                         | Medium · ✅<br><b>FIXED</b> (M-3)                | Credential stuffing                                                                                                                                                                  | ~~Login-specific limiter on all hosts~~<br>— done: cbs-login policy in<br>AddCbsFramework / UseCbsFramework<br>(all 5 hosts), per client IP + path, 10/60s,<br>429 + Retry-After , on both credential<br>POSTs. Its prerequisite shipped with it —<br>CIDR KnownNetworks so the Docker<br>multi-host stack actually trusts the<br>gateway, malformed trust entries failing<br>startup, and a once-per-start warning<br>when a proxy's header is discarded as<br>untrusted. 25 pinned tests. Gateway<br>limiter and DB lockout both retained as<br>complementary layers |
| 18 | PII masking missing on thin<br>hosts                                 | Medium · ✅<br><b>FIXED</b> (M-4)                | Half-masked logging on 4 of 5 hosts<br>— name redaction on, <b>regex<br/>redaction silently off</b> (empty<br>Patterns default), so PAN/Aadhaar<br>in free text was written in clear | ~~Share masking config across hosts~~<br>— done: canonical logmasking.json<br>linked into every host, loaded<br>optional: false before the pipeline,<br>env provider re-added after;<br>LogMaskingConfigTests (mutation-<br>verified). Remaining in-area: <b>M-5</b><br>( LogParameterValues )                                                                                                                                                                                                                                                                         |
| 19 | Duplicated host bootstrap +<br>service helpers                       | Low                                             | Shotgun surgery                                                                                                                                                                      | Extract AddCbsHost / UseCbsHost +<br>shared helpers                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 20 | Committed node_modules ,<br>empty _CommonPackages , junk<br>entities | Low                                             | Repo bloat/confusion                                                                                                                                                                 | gitignore; delete; generation allowlist                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |

| #  | Issue                                                               | Severity                                                          | Impact                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Recommendation                                                                                                                                                                                                                                               |
|----|---------------------------------------------------------------------|-------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 21 | Login <i>attempt</i> deactivates a dormant account                  | <b>Medium</b> · 🚩<br><b>NEW (2026-07-30)</b>                      | <code>AuthenticationService</code> runs the dormancy sweep during login and writes <code>a_User.STATUS = 3</code> when the last logout is older than <code>b_LoginPolicy.DeactivateDays</code> (90). The failed attempt is what deactivates the account, and there is <b>no self-service or admin path back</b> — only a DBA <code>UPDATE</code> . Two accounts were deactivated this way while building the E2E suite.                                                                                                                                                                                                                                                                                                                                         | Add a reactivate action to <code>/Administration/ConnectedUsers</code> (the screen already exists and is password-gated); consider making the sweep a scheduled job rather than a login side-effect, so a login attempt reads policy instead of enforcing it |
| 22 | Signed cookie + closed session ⇒ infinite redirect loop             | <b>Medium</b> (High in multi-host) · 🚩<br><b>NEW (2026-07-30)</b> | <code>/Account/Login</code> is <code>[CbsAllowAnonymous]</code> , so <code>CbsAccessMiddleware</code> never validates the session there. The controller sees the rehydrated cookie, treats the caller as authenticated and redirects to <code>/Modules</code> ; <code>/Modules</code> <b>is</b> guarded, finds no open <code>b_UserLogTime</code> row, and redirects back — <code>ERR_TOO_MANY_REDIRECTS</code> . <b>The user cannot reach the login form to recover</b> without clearing cookies. Reachable in normal operation: admin force-logout via <code>/Administration/ConnectedUsers</code> , logout on another host holding the shared SSO cookie, or a server session that lapsed while the cookie lives. Proven in a real browser.                  | On the login GET, treat a cookie whose session is not open as anonymous — sign out and render the form — instead of redirecting; the guard's own <code>reason=sessionexpired</code> bounce should also clear the cookie                                      |
| 23 | <code>Model.Disabled</code> undone at runtime on the account picker | <b>Low (latent)</b> · 🚩<br><b>NEW (2026-07-30)</b>                | Razor renders <code>Go disabled</code> and the segments <code>readonly</code> , then <code>cbs-account-picker.js</code> <code>init</code> runs <code>unlock(cfg)</code> — <code>goBtn(cfg, false)</code> + <code>el.readOnly = !cfg.goEnabled</code> — neither consulting the disabled state (the config carries no <code>disabled</code> flag). A disabled <b>and empty</b> picker comes back editable, letting a read-only screen change the posted account id. <b>Latent, not live:</b> the one production consumer ( <code>AccHoldingAmount</code> , <code>Disabled = isEdit</code> ) always has a populated account in edit mode, which takes the safe <code>lock()</code> branch. It bites the first screen that renders a disabled picker with no value. | Pass <code>disabled</code> through in the <code>data-cbs-account</code> config and have <code>lock / unlock</code> honour it                                                                                                                                 |
| 24 | Component showcase demonstrates <code>clearTargets</code> backwards | <b>Low</b> · 🚩 <b>NEW (2026-07-30)</b>                            | <code>Views/Components/Index.cshtml:167</code> puts <code>clearTargets</code> on the <b>child</b> picker pointing at its own fields, so the dependent lookup blanks itself on every pick and can never hold a value.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Move <code>clearTargets</code> to the parent State picker in the showcase                                                                                                                                                                                    |

| # | Issue | Severity | Impact                                                                                                                                                                                                                    | Recommendation |
|---|-------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|
|   |       |          | clearTargets means "downstream fields this selection invalidates" and belongs on the parent —<br>Views/Taluka/Index.cshtml:59 is correct. The component is fine; the <b>reference demo developers copy from</b> is wrong. |                |

## 13. Architecture Scorecard

| Category              | Score /10 | Basis                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution Structure    | 8         | Clean acyclic layering, modular monolith, arch-tested; docked for bare-DLL refs + shared root namespace                                                                                                                                                                                                                                                                                                                  |
| Maintainability       | 7         | Excellent factoring; docked for host/helper duplication + stale docs                                                                                                                                                                                                                                                                                                                                                     |
| Scalability           | 4         | Fine to ~1–10k; single-node session + in-memory paging cap it beyond                                                                                                                                                                                                                                                                                                                                                     |
| Performance           | 5         | Great async; account picker's round-trips fixed (24→1, ~2× faster, 2026-07-30). <b>Still docked for all three original reasons</b> — <i>load-all</i> (blocked on a DBA index, measured), <i>no caching</i> (infra built + fail-open + proven by BankVars ; <b>scope deferred by decision</b> , only BankVars wired), <i>no retry</i> ( <b>backlogged</b> , gated on write-idempotency rules). Nothing yet lifts the cell |
| Security              | 3         | Auth bypass, reversible passwords, no CSRF, committed secrets                                                                                                                                                                                                                                                                                                                                                            |
| Testability           | 7         | Service + arch suites, plus a controller/HTTP tier ( ...UI.IntegrationTests , real pipeline in-process) and a browser tier ( Tf1Cbs.E2E , Playwright) — the "no controller/E2E tests" dock is cleared. Still docked for the unmockable DAL ( DataAccess is sealed , no IDataAccess ), a live-DB dependency in every authenticated tier, and <b>no CI to run any of it</b> (H-3)                                          |
| Extensibility         | 8         | Module system, reusable components with safe defaults, config-driven cutover                                                                                                                                                                                                                                                                                                                                             |
| Code Quality          | 8         | Consistent, single-responsibility, well-documented                                                                                                                                                                                                                                                                                                                                                                       |
| Database Design       | 6         | Sound schema reuse + real transactions; versioned DDL + a migration runner (#12) and a concurrency-token pattern (H-6) now exist; docked for the H-6 rollout still pending, no 0000 schema baseline, junk tables                                                                                                                                                                                                         |
| API Design            | 6         | Clean MVC + attribute routing + DTOs; no REST/versioning story (server-rendered app), no antiforgery                                                                                                                                                                                                                                                                                                                     |
| Dependency Management | 6         | CPM centralized; docked for bare-DLL Debug refs + DIP leak                                                                                                                                                                                                                                                                                                                                                               |
| Deployment Readiness  | 5         | Four deploy shapes + good scripts/health checks; no CI/CD/IaC, root-user containers                                                                                                                                                                                                                                                                                                                                      |
| Observability         | 7         | Logging/correlation + OpenTelemetry traces/metrics/DAL spans, correlated, gateway→host→DB proven; docked for prod dashboards / SLO-alerting / logs→Loki                                                                                                                                                                                                                                                                  |
| Documentation         | 9         | Exceptional and current                                                                                                                                                                                                                                                                                                                                                                                                  |

**SOLID (1–10):** SRP **8** (small cohesive units), OCP **7** (module/port extension points, config gating), LSP **7** (little inheritance, no obvious violations), ISP **9** (tiny interfaces), DIP **6** (ports pattern correct but Framework references concrete services + service-locator for optional ports).

**Overall: 62 / 100 (as reviewed 2026-07-10; ~77 after remediation — see the progress banner)**

Craft and structure score high; security, scalability, observability, and deployment maturity pull it down to a **strong pre-production foundation** rather than a shippable banking system. Update (2026-07-18): C-1/C-2/H-1/H-4/M-1 fixed + H-2 partial (Security ~3→~7), plus Observability instrumentation (Observability 4→~6) and the H-6 State pilot — overall to ~74. Update (2026-07-30): **#12 DB migration tooling** shipped — versioned per-provider DDL + a journalled runner, verified live on SQL Server and Oracle (Database Design 5→6) — overall to ~75. Update (2026-07-30): the **controller/HTTP and browser test tiers** shipped ( `...UI.IntegrationTests` + `TfLCbs.E2E` ), closing the ~90-band test row and clearing the largest of Testability's three docks (Testability 5→7) — overall to ~76; held to +1 rather than the row's +1.5 because **H-3 (CI) still runs none of it**. Update (2026-07-31): **M-4 closed** — PII masking config made canonical and shared to all five hosts; the thin hosts had been **half-masked** (name redaction on, regex redaction silently off), not unmasked as the finding said — overall to ~76.5. Update (2026-07-31): **M-3 closed** — a `cbs-Login` rate-limit policy in the framework, so all five hosts throttle the credential POSTs and not just the gateway (whose limiter was volumetric, ~600 guesses/min), plus the forwarded-headers trust that makes the per-client partition real in the Docker multi-host stack — overall to ~77. That closes the last ~90-band Security row that is pure application code; what remains under Security is process (threat model, pen test, WAF) and ops (HSTS strengthening, `sa` rotation). The Security cell stays at its as-reviewed 3 (this scorecard records the 2026-07-10 baseline; current Security is ~7 per the banner). Green gate still pends **H-3 (git + CI)** and **H-6 rollout to the remaining write services** (🚧 pattern proven on State).

## 14. Refactoring Roadmap

### Critical — must fix before *any* production exposure

- **✓ DONE — auth bypass (C-1)** — fail-closed guard; never succeeds on an unverified credential; pinned test.
- **✓ DONE — salted password hashing (C-2)** — PBKDF2 `PasswordHash` primitive + full migration (all 1,731 users) + login & change-password verification.
- **✓ DONE — global antiforgery (H-1)** — `AutoValidateAntiforgeryToken` in `AddCbsFramework` + AJAX token header.
- **⚠ MOSTLY — remove committed secrets (H-2)** — secrets out of committed config (gitignored dev creds + prod env/secret-store). *Still to do (external):* rotate `sa`, least-privilege login, real TLS cert (drop `TrustServerCertificate=true`).
- **✓ DONE — guard-ordering assertion (H-4)** — `EnsureEndpointRoutingRegistered()` throws at startup if `UseCbsFramework()` precedes `UseRouting()`; 2 pinned tests.
- **✓ DONE — security headers (M-1)** — `UseCbsSecurityHeaders` (first middleware, all 5 hosts): fully strict enforced CSP ( `script-src / style-src 'self'`, no nonce/no `unsafe-inline` ) + X-Frame-Options/nosniff/Referrer-Policy/Permissions-Policy; inline scripts/handlers/styles refactored out.
- **Stand up source control + CI (H-3)** — *Medium*. ← next. Git repo; pipeline running build + `dotnet test` + a security scan + secret scan on every change.

### High Priority

- **Optimistic concurrency** on write paths — *Medium*. `rowversion` + `WHERE rowversion=@orig`.
- **Distributed session + gateway affinity** — *Medium–Large*. Redis-backed session; YARP `SessionAffinity`.
- **🕒 PARTIAL — DB-side filter/sort/page** for large list screens, provider-dialected — *Medium*. The account picker's **round-trips** are fixed (one server-side join, 24→1, ~2× faster, verified on SQL Server + Oracle). **DB-side paging is deferred on evidence:** measured 3.6–11× *slower* on 54 of 55 branches because the paged join full-scans `G_GLOBALCLIENT` (166k logical reads for 15 rows), unfixable by query hints or restructuring. Needs an index on `B_ACCOUNT(ORGELEMENTID, ACCOUNTSTATUSCODE, ACCOUNTNUMBERFORDISPLAY)` — i.e. **DBA work, not coding work** — then re-measure. `docs/perf/AccountList-baseline-2026-07-30.md`.
- **✓ DONE — Security headers (M-1)**: fully strict CSP + X-Frame-Options/X-Content-Type-Options/Referrer-Policy/Permissions-Policy — see Critical section.
- **✓ DONE — DB migration tooling (#12)** — `TfLCbs.Tools.DbMigrator` (DbUp): the five hand-run `.sql` files are now numbered, immutable, per-provider migrations embedded in the tool, applied once each and journalled to `CbsSchemaVersions`. `deploy-cbs.ps1` checks for drift (opt-in `-Migrate` applies); Docker exposes a `migrate` compose profile. Runbook:

docs/deploy/db-migrations.md . Verified end-to-end on two live providers: SQL Server (dev) and Oracle (dev TFLCBS — where 0001 / 0002 did real work and 0003 's already-exists guard fired). Remaining: script the legacy schema as an already-applied 0000 baseline; the PostgreSQL scripts are still unrun on a live instance.

- **✓ DONE — Login rate limiting on all hosts (M-3)** — cbs-login policy registered in AddCbsFramework and inserted first by UseCbsFramework , so every host has it, gateway or not; per client IP + path, 10/60s default, 429 + Retry-After , on both credential POSTs. The gateway's volumetric limiter and the DB per-account lockout are retained as complementary layers. Shipped with its own prerequisite — CIDR KnownNetworks trust for the Docker multi-host stack, malformed trust entries failing startup, and a once-per-start warning when a proxy's X-Forwarded-For is discarded as untrusted (the misconfiguration that would otherwise turn the per-client partition into one shared bucket, silently). 25 pinned tests.
- **✓ DONE — PII masking shared to thin hosts (M-4)** — canonical logmasking.json linked into all five hosts, loaded optional: false before the logging pipeline; the thin hosts were **half-masked** (empty Patterns default), not unmasked. LogMaskingConfigTests pins it, mutation-verified.

## Medium Priority

- **✓ DONE (instrumentation) — OpenTelemetry** traces + metrics + OTLP + DAL spans + log-trace correlation (AddCbsObservability , all 5 hosts + gateway, off by default). Remaining = ops: stand up the backend/dashboards/SLO alerting (Collector → Prometheus/Tempo + Grafana, or a SaaS APM).
- **Polly transient-retry + circuit breaker** on DB calls — Small-Medium.
- \*Extract .Abstractions assembly (**fix DIP leak**) + fix bare-DLL Debug refs\* (ProjectReference/NuGet, Release closure, build-order edge) — Medium.\*
- **Extract AddCbsHost / UseCbsHost** (kill 5× bootstrap duplication) + **shared service helpers** — Small.
- **Container hardening**: non-root USER , HEALTHCHECK in the Dockerfile — Small.
- **DR/HA design**: DB Always-On, RTO/RPO, DR runbook — Large.

## Nice to Have

- Prune unused jQuery/validation, empty \_CommonPackages , committed node\_modules , junk entity tables; fix LASTMODIFIEDON typo at generation.
- Update stale docs ( CLAUDE.md command-dispatch, compose.multi.yaml ).
- Introduce lightweight value types for money/account if the domain grows.
- ~~Controller + E2E (Playwright) tests~~ **done 2026-07-29/30** ( ...UI.IntegrationTests + TflCbs.E2E ); **make the DAL mockable for true unit tests** — still open, and now the binding constraint on Testability: every authenticated tier of all four suites needs a live database because DataAccess is sealed with no IDataAccess ( IRepository<T> exists, but DataAccess.Repository<T>() hands back the concrete Repository<T> ).
- Audit denied-access attempts (framework TODO ).

## Road to 100 — remaining work by category

**Just want the shape of it?** [REMEDATION-PLAN.md §0](#) — *At a glance, what's left* is a one-screen version: the two items blocking a green gate, the four known open defects, the ~80/~90 bands in a line each, and the migration. The table below stays the authoritative one — owners, bands, effort and per-item progress.

(Current: ~77 — Observability instrumentation, the H-6 State pilot, #12 DB migration tooling, the controller/browser test tiers, M-4 (PII masking) and M-3 (login rate limiting) have landed since the ~72 mark. Grouped by who owns it — **Coding** = application code in this repo · **Infra** = platform/pipeline/hosting (DevOps + ops) · **Other** = DBA credential/cert work + one-off security-process engagements. "Shared" straddles two. **+pts = tentative overall-score gain** if that item is completed — a **holistic estimate for prioritisation, not an exact additive sum**; the overall is a judgment call, and ship-blockers lift the number more than their own cell because they stop suppressing the whole score. **Progress** states how far each item actually is —  done ·  partial (what landed, what is left) ·  not started — so a partially-collected item is never read as finished.)

| Item                                                                                                                                                  | Progress                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Category                   | Band     | +pts (est.)           | Effort |
|-------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|----------|-----------------------|--------|
| <b>H-6</b> optimistic concurrency (rowversion + guarded UPDATE across write services)                                                                 |  <b>StateService DONE — the reference implementation; every other write service must now follow it.</b> State carries <code>G_STATE.VERSION</code> as <code>[DbColumn(IsRowVersion = true)]</code> , so TfiOmniDb auto-increments it in the SET clause, appends <code>AND VERSION = @expected</code> to the WHERE, and throws <code>ConcurrencyException</code> on 0 rows; <code>StateService.UpdateStateAsync</code> catches that and disambiguates "changed by another user" from "already deleted". Proven on the dev DB by a passing conflict theory, and the signature did not change, so there was no controller/view/Demo churn. <b>The rollout is a repeat of three mechanical steps per service</b> — (1) add the <code>VERSION</code> column via a migration, (2) mark it <code>IsRowVersion</code> on the entity in a hand-authored partial, (3) call <code>UpdateAsync(entity, cols)</code> and catch <code>ConcurrencyException</code> . Until that is done, <b>every write path except State is still last-writer-wins.</b> | Coding                     | ~74 gate | +2                    | M      |
| <b>H-3</b> — git init + CI pipeline (build/test/arch/secret-scan/SAST)                                                                                | <input type="checkbox"/> <b>Not started.</b> The single largest remaining gate item — the working tree is still not a repository.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Infra                      | ~74 gate | +2                    | M      |
| <b>H-2 finish</b> — rotate <code>sa</code> , least-privilege SQL login, real TLS cert (drop <code>TrustServerCertificate</code> )                     |  <b>Partial.</b> Secrets are out of committed config; the three remaining actions are DBA/ops, not code.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Other (DBA/ops)            | ~74 gate | +1                    | S-M    |
| Distributed session (Redis) + gateway affinity                                                                                                        | <input type="checkbox"/> Not started. <code>CbsSessionStore</code> is still single-node in-memory.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Coding + Infra             | ~80      | +1.5                  | M-L    |
| <b>Observability instrumentation</b> — OTel traces/metrics + OTLP + log-trace correlation, all 5 hosts + gateway ( <code>AddCbsObservability</code> ) | <input checked="" type="checkbox"/> <b>Instrumentation done</b> (gateway→host→DB proven). <input type="checkbox"/> Prod backend / dashboards / SLO alerting still to stand up — ops, not code.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Coding + Infra             | ~80      | +1 done · +0.5 ops    | M      |
| <b>Performance — DB-side filter/sort/page on large lists</b> — see <code>docs/perf/AccountList-baseline-2026-07-30.md</code>                          |  <b>One third done.</b> Account picker converted to one server-side join: 24→1 round-trips, ~2× faster, SQL Server + Oracle verified. DB-side paging <b>measured as a 3.6–11× regression</b> (paged join full-scans <code>G_GLOBALCLIENT</code> , 166k reads for 15 rows) → blocked on <code>B_ACCOUNT(ORGELEMENTID, ACCOUNTSTATUSCODE, ACCOUNTNUMBERFORDISPLAY)</code> , i.e. <b>DBA not Coding</b> . Of the other two thirds: <b>reference caching</b> — infra is built ( <code>IReferenceCache</code> : distributed, fail-open, proven by <code>BankVars</code> ), scope <b>deferred by decision</b> ; <b>Polly retry</b> — <b>backlogged</b> , seam settled at TfiOmniDb's <code>CommandLogger.ExecuteAsync</code> , gated on write-                                                                                                                                                                                                                                                                                                | Coding (paging: Other/DBA) | ~80      | +0.5 done · +1.0 left | M      |



| Item                                                                                                                                                                                         | Progress                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | Category              | Band | +pts (est.)     | Effort |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|------|-----------------|--------|
|                                                                                                                                                                                              | idempotency classification. Both tracked in BACKLOG.md .                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |                       |      |                 |        |
| <b>DB migration tooling + versioned DDL</b> —<br>Tf1Cbs.Tools.DbMigrator (DbUp), per-provider numbered scripts, CbsSchemaVersions journal, deploy-script drift check, Docker migrate profile | <input checked="" type="checkbox"/> <b>Done</b> , verified live on SQL Server and Oracle.<br><input type="checkbox"/> Remaining: a 0000 legacy-schema baseline (so an empty DB is reproducible) and a live PostgreSQL run.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | <b>Coding + Infra</b> | ~80  | <b>+1 done</b>  | M      |
| ~~Controller + end-to-end (Playwright) test coverage~~                                                                                                                                       | <input checked="" type="checkbox"/> <b>DONE (both halves).</b><br>Tf1Cbs.IntegrationTests (2026-07-29, 23 tests, ~2s) boots the real Program via WebApplicationFactory , so middleware <b>order</b> is under test; its guard/antiforgery half needs no database. Tf1Cbs.E2E (2026-07-30, 80 tests, exit 0) drives a real browser — Playwright/TypeScript, outside the .slnx , <b>no app source changes</b> . Components are covered against the Development-gated /Dev/Components showcase (canned data, TempData-only notifications), so the bank database is never written; real screens self-calibrate against menu rights and skip with a reason. Found and pinned <b>3 real defects</b> ( Model.Disabled undone at runtime on the account picker; the showcase's dependent picker clearing itself; a signed-cookie/closed-session <b>infinite redirect loop</b> on /Account/Login ). <b>Banked as ~+1, not +1.5</b> — nothing runs these automatically until <b>H-3 (CI)</b> lands. | <b>Coding</b>         | ~90  | ~~+1.5~~ banked | M      |
| Row-token bypass tests + multi-host SSO browser flow (residue of the row above)                                                                                                              | <input type="checkbox"/> <b>Not started — named separately so "test coverage <input checked="" type="checkbox"/> " does not read as "everything tested."</b> RowToken makes four promises (unforgeable / screen-bound / session-bound / single-use) and <b>none of the negative cases is covered</b> ; the suites only prove a <i>valid</i> token round-trips and that ids never travel as bare integers. Each is a distinct bypass if it regresses. This was blocked at the integration tier (tokens embed the session id, the consumed-nonce set is server-side, and a tokenless POST 400s at antiforgery before the token check) — <b>the browser tier removes that blocker</b> , since a cookie jar and antiforgery round-trip are free in Playwright, making this now the cheapest place to close it. Also open: the gateway login / global-logout flow across the multi-host farm, verified by hand once with nothing pinning it.                                                  | <b>Coding</b>         | ~90  | +0.5            | S–M    |
| IaC / Kubernetes (repeatable infra)                                                                                                                                                          | <input type="checkbox"/> Not started. Four deploy shapes are scripted but not declarative.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | <b>Infra</b>          | ~90  | +1.5            | L      |

| Item                                                                 | Progress                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Category                 | Band | +pts (est.)      | Effort      |
|----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|------|------------------|-------------|
| DR / HA / backup posture                                             | <input type="checkbox"/> Not started. No RTO/RPO defined.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Infra                    | ~90  | +1               | L           |
| Penetration test                                                     | <input type="checkbox"/> Not started (external engagement).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Other (security process) | ~90  | +1               | External    |
| Container hardening (non-root, HEALTHCHECK, image scan)              | <input type="checkbox"/> Not started. Containers still run as root.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Infra                    | ~90  | +0.5             | S–M         |
| WAF in front of the app                                              | <input type="checkbox"/> Not started (procurement decision).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Infra                    | ~90  | +0.5             | S (procure) |
| ~~PII masking shared to thin hosts~~                                 | <p>✅ <b>DONE (2026-07-31)</b>. The finding was <b>under-stated</b>: the thin hosts were <b>half-masked</b>, not unmasked — <code>MaskingOptions</code> defaults <code>Keys</code> to the banking PII list but defaults <code>Patterns</code> to <b>empty</b>, so name-based redaction worked while value-regex redaction (PAN/Aadhaar in free text) silently did not, on the four hosts that serve the domain screens. Config extracted to a canonical <code>Tf1Cbs.Host.Main/logmasking.json</code> (<b>deleted</b> from <code>appsettings.json</code> — no second copy), linked into all four thin hosts like <code>route takeover.json</code>, loaded from <code>AppContext.BaseDirectory</code> <b>before</b> <code>ConfigureTf1Logging()</code> and <b>optional: false</b> (a missing file would degrade to half-masked logging silently, so the host now refuses to start), with <code>AddEnvironmentVariables()</code> re-added after so <code>Tf1Log__Masking__*</code> still overrides. Pinned by <code>LogMaskingConfigTests</code> (4 facts, <b>mutation-verified</b>). <b>Full +0.5 taken</b> — the fix ships with the build whether or not CI exists; only the guard's value waits on H-3. <input type="checkbox"/> Not covered: <b>M-5</b> (<code>Database:LogParameterValues</code>) and an end-to-end assertion on a real log file.</p> | Coding                   | ~90  | <b>+0.5 done</b> | S           |
| ~~Login-specific rate limiting on all hosts (not just the gateway)~~ | <p>✅ <b>DONE (2026-07-31)</b>. The finding was <b>two gaps, not one</b>: the gateway's limiter was <i>volumetric</i> (600/60 s over all traffic — ~600 password guesses a minute) <i>and</i> absent from any host reached without it, including the whole single-host shape. Both closed by one control in the framework: <code>AddCbsFramework</code> registers the <code>cbs-login</code> policy, <code>UseCbsFramework</code> inserts <code>UserRateLimiter()</code> <b>first</b> (cheapest possible rejection — before session, cookie decryption or DB), and the two credential POSTs opt in with <code>[EnableRateLimiting]</code>. Since <code>AccountController</code> lives in <code>Tf1Cbs.Core.Authentication.Web</code> — an application part in <b>all 5 hosts</b> — one attribute covers every deployment shape. Partition = <b>client IP + path</b>, so a burst on login can't lock</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Coding                   | ~90  | <b>+0.5 done</b> | S           |

| Item                                                               | Progress                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Category                        | Band    | +pts (est.) | Effort       |
|--------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|---------|-------------|--------------|
|                                                                    | <p>everyone out of change-password. Default 10/60 s, Security.LoginRateLimit ; disabled still <b>registers</b> the policy as a no-limiter (an unregistered name would 500 the login page), and a zero/negative value is a <b>startup error</b>, never a silent "off". Pinned by 9 tests, incl. a fixture guard proving the pinned limit reaches the framework (the first draft silently didn't — eager config reads don't see ConfigureAppConfiguration ). <input type="checkbox"/> Not covered: the <b>per-username</b> dimension stays with the DB lockout ( MAXIMUMLOGINATTEMPT ) — partitioning on the posted username needs a sync form-body read, which Kestrel disables; the per-user partition behind the gateway is now real ( ForwardedHeaders gained CIDR KnownNetworks , the Docker multi-host stack trusts the gateway, malformed trust entries fail startup and a <i>missing</i> one is warned about once per host start — 16 further tests), but <b>IIS farms still set KnownProxies by hand</b> — now detectable in the log rather than silent, though still not enforced.</p> |                                 |         |             |              |
| Threat model                                                       | <input type="checkbox"/> Not started (workshop).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | <b>Other</b> (security process) | ~90     | +0.5        | S (workshop) |
| HSTS strengthening (1-yr max-age + includeSubDomains / preload )   | <input type="checkbox"/> Not started — deliberately deferred; preload is hard to reverse.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | <b>Other</b> (ops decision)     | backlog | +0.5        | S            |
| <b>Migration completeness</b> — port the remaining ~98% of screens |  <b>~2% ported</b> . 12 domain screens / 47 views across 8 promoted domains — the vertical slice is proven; the volume is not.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | <b>Coding</b>                   | ~100    | <b>+9</b>   | XL           |

**Band subtotals (ladder from the original ~72 baseline; now at ~77):** gate items +5 → ~76–77 · ~80-band shared/perf +5.5 → ~81–82 · ~90-band hardening/test/security +5.5 → ~89–90 · migration completeness +9 → ~99–100. (Totals ~+25 remaining, on top of the ~+2 already banked — ~+1 for the test row, +0.5 for PII masking, +0.5 for login rate limiting; treat as directional.)

**How to prioritise with this:** best **points-per-effort** are the two gate items — **H-6 (pure Coding)** and **H-3 (pure Infra)** — cheap, high-value, and parallelisable across people; do them first. The ~80-band shared items (Redis, OTel, DB-side paging) are the next-best ratio. The ~90 band is many small-to-medium items with diminishing per-item returns (mostly Infra + security process). The last **+9 to 100 is the migration itself** — by far the largest effort and unavoidable, but pure volume, not architecture: nothing there needs a redesign (structure already scores 8/10).

**Observability (OTel) — what the +1.5 buys, and the shape of the work.** Of the three pillars (logs / metrics / traces), only **logs** are present ( TflLog : structured, correlation Reference , categories incl. Performance/Request, per-request middleware). **Metrics and traces are missing** — no request rate / p95–p99 latency / error rate, and no gateway→host→DB span tree — which is the "blind in production" gap: you learn of problems from user complaints, and there's nothing to alert on. OpenTelemetry is **vendor-neutral** — instrument once (**turnkey auto-instrumentation** for ASP.NET Core + HttpClient , and **DB spans free for SQL Server via Microsoft.Data.SqlClient and for PostgreSQL via Npgsql's built-in OTel**), export to any backend. (Oracle's managed provider emits no OTel spans; and because **TflOmniDb is editable in-house source** — not a bare DLL — uniform DB spans across all three providers, with the SQL/provider/row-count/correlation-id the DAL already tracks, come from adding a **single ActivitySource at the DAL's**

*existing central command seam* — *one place, not per-call-site.*) High-value 80/20: **RED metrics** (rate/errors/duration per endpoint) + auto-traces, with **W3C** `traceparent` **propagated across the YARP gateway** so a request is a single trace, and the OTel trace-id **unified with the existing correlation** `Reference` so a log line links to its trace. The real cost is **Infra/ops, not code**: standing up and operating the backend — OTel Collector → Prometheus/Tempo + Grafana (**self-hosted**, for data-residency) or **SaaS** (App Insights/Datadog) — with retention, dashboards and SLO alerting. Post-gate Medium (the app runs; logs give forensics) — best paired with the Redis stood up for distributed session and with H-3's pipeline. **Decision that drives it: self-hosted vs SaaS backend (data-residency + ops capacity).**

## 15. Production Readiness Checklist

| Area                                               | Status                                                                                                                                                                                                                                                                                   |
|----------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Authentication sound (no bypass, hashed passwords) | ✅ <b>Fixed</b> (C-1 guard + C-2 PBKDF2)                                                                                                                                                                                                                                                  |
| CSRF protection                                    | ✅ <b>Fixed</b> (H-1 global antiforgery)                                                                                                                                                                                                                                                  |
| Secrets externalized, least-privilege DB           | ⚠️ <b>Partial</b> (H-2: externalized; <code>sa</code> rotation + least-priv login pending)                                                                                                                                                                                               |
| Security headers / HSTS / secure cookies           | ✅ <b>Headers fixed</b> (M-1: strict CSP + companions); ⚠️ HSTS stock/prod-only (strengthening backlogged); cookie flags deploy-dependent                                                                                                                                                 |
| Source control + CI/CD + automated tests gate      | ❌ Missing                                                                                                                                                                                                                                                                                |
| DB change management / migrations                  | ❌ Missing                                                                                                                                                                                                                                                                                |
| Concurrency correctness on writes                  | ❌ Missing                                                                                                                                                                                                                                                                                |
| Horizontal scalability (distributed session)       | ❌ Missing                                                                                                                                                                                                                                                                                |
| Health checks (liveness/readiness)                 | ✅ Present                                                                                                                                                                                                                                                                                |
| Structured logging + correlation                   | ✅ Present                                                                                                                                                                                                                                                                                |
| PII redaction in logs                              | ✅ <b>Present on every host</b> (M-4 fixed 2026-07-31: canonical <code>logmasking.json</code> , name + regex redaction, optional: <code>false</code> , test-guarded); ⚠️ <b>M-5 open</b> — <code>Database:LogParameterValues</code> can still log parameter values if enabled outside Dev |
| Metrics / tracing / APM                            | ✅ <b>Instrumented</b> (OTel traces+metrics via <code>AddCbsObservability</code> ); ⚠️ prod backend/dashboards/alerting = ops                                                                                                                                                             |
| DR / HA / backup posture                           | ❌ Missing                                                                                                                                                                                                                                                                                |
| Container hardening (non-root, healthcheck)        | ⚠️ Partial                                                                                                                                                                                                                                                                               |
| Rate limiting / brute-force defense                | ✅ <b>Present on every host</b> (M-3 fixed 2026-07-31: <code>cbs-login</code> policy on both credential POSTs, 429 + <code>Retry-After</code> , test-guarded) + gateway volumetric limiter + DB per-account/IP lockout; proxy trust (which decides                                        |

| Area                       | Status                                                                                                                                                                                                                                                                                                                        |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                            | whether the partition is per-user or per-gateway) is now wired in the Docker multi-host stack, fails startup if malformed, and logs a <code>Security</code> warning once per host start if a proxy's header is being discarded; ⚠ IIS farms still set <code>KnownProxies</code> by hand — detectable in the log, not enforced |
| Access control fail-closed | ✅ Present (H-4: ordering now asserted at startup)                                                                                                                                                                                                                                                                             |
| Migration completeness     | ❌ ~<2% of screens                                                                                                                                                                                                                                                                                                             |

**Gate decision: DO NOT DEPLOY** to production banking use until the Critical + High rows are green. The foundation is sound enough that closing them is a matter of focused work, not redesign.

## 16. Enterprise Readiness Verdict

*If a senior engineer at Microsoft / Google / Amazon / Netflix / Stripe submitted this:*

- **Would it pass an architecture review?** As a **mid-migration reference architecture / vertical slice** — yes, with commendation for the framework, the Result discipline, the module system, and the docs. As a **production core banking system** — no; it would be sent back on security and operational readiness.
- **What they'd praise:** the horizontal framework factoring, `Result` + async discipline, arch-tested boundaries, the reusable-component design, the reference cache, the structured logging library, and the documentation quality. Several reviewers would ask to *reuse* the framework/logging patterns.
- **What they'd criticize:** the auth bypass and reversible passwords (a Stripe/Amazon security reviewer would treat C-1 as a launch-blocking incident), no CSRF, committed secrets, and — culturally striking — **no source control or CI**. They'd flag the single-node session store as a scale-out blocker and the absence of metrics/tracing as "flying blind."
- **What they'd ask to redesign:** password/credential handling; session/state for horizontal scale; DB-side query/paging for large tables; the bare-DLL/Debug reference scheme; extraction of the abstractions assembly.
- **What they'd reject completely:** shipping to production with C-1/C-2/H-1/H-2 open. Everything else is roadmap, not rejection.

## 17. Final Recommendations

1. **Treat this as a foundation, not a product.** The architecture is a well-built chassis. Do not let its polish mask that <2% of the banking surface is migrated and the highest-risk money-movement path is still in the excluded Lab project.
2. **Close the four security blockers first (C-1, C-2, H-1, H-2)** — they are small-to-medium effort and non-negotiable for a bank. C-1 (auth bypass) is a same-day fix and should be done immediately.
3. **Stand up the engineering safety net now, not later** — git + CI (build/test/secret-scan/SAST) will catch the *next* C-1 before it ships. Its current absence is the single biggest process risk.
4. **Solve concurrency and horizontal scale before load, not after** — add rowversion concurrency checks and move session to a distributed store with gateway affinity; both are architecture-shaping and cheaper now than post-launch.
5. **Add the observability and DB-migration pillars** — OpenTelemetry ✅ (instrumentation done — traces/metrics/DAL spans/correlation, gateway→host→DB proven; prod backend/dashboards remain) + a versioned migration tool (still to do) are prerequisites for operating a regulated system, independent of feature progress.
6. **Preserve what's good.** The framework, Result pattern, module system, reusable components, logging library, and documentation are genuine assets — the roadmap above hardens them; it does not replace them.
7. **Right-size the multi-provider investment.** If SQL Server is the only production target, the Oracle/PG DAL and per-method perf harnesses are cost without payoff. Decide explicitly. (*Updated 2026-07-29: the original "and the SQL-Server-only search paging already breaks the promise" caveat is gone — that path was removed, so the multi-provider claim is now consistent end-to-end. The decision is a cost/benefit one, not a "the promise is already broken" one.*)

**Bottom line:** Excellent craft on an incomplete, not-yet-secure system. Fix the concentrated Critical/High items, add the missing operational pillars, and this becomes a genuinely strong enterprise platform. Ship it as-is and it fails an audit on day one.

---

*Prepared as a formal architecture review. All findings are anchored to source; headline Critical findings were verified directly against the code. Where a claim depends on runtime config (e.g. the `MFA_AD_LOGIN_ENABLED` flag state, the presence of the `X_SCROLL` unique constraint), the review says so — those warrant confirmation against the live environment before sign-off.*